SUM : spécifications techniques pour l'hébergement à la NPSP

- **Application :** SUM, Suivi de l'Utilisation de mSupply (tableau de bord du monitoring DQA)
- **Objet :** préparation de la migration vers l'infrastructure de la NPSP
- **Date :** 28 octobre 2026

---

1. Présentation de l'application

SUM est une application web interne. Elle calcule et affiche des indicateurs de qualité des données mSupply pour 40 sites sanitaires : scores PAQD par site, synthèse nationale, suivi des stocks des produits traceurs.

- **Utilisateurs :** coordination nationale, équipes district, DAP, soit quelques dizaines de comptes. Consultation surtout en réunion, depuis un navigateur. Trafic faible.
- **Alimentation :** aucune connexion à mSupply. La DAP transmet chaque semaine un classeur Excel (environ 5 Mo, 32 Mo au plus), déposé par la coordination dans l'interface web. L'application le contrôle, l'importe, puis recalcule les indicateurs (une à deux minutes).
- **Aucun envoi sortant :** pas de courriel, pas de SMS, pas d'appel à un service tiers.

2. Architecture

Trois services applicatifs, livrés en conteneurs Docker, sur un seul serveur :

```
Navigateurs (HTTPS 443)
         |
+--------v---------+
| web : Nginx 1.27 |  TLS, sert l'interface, relaie /api
+--------+---------+
         |  réseau interne Docker (non exposé)
+--------v---------+
| api : Node.js 24 |  API REST, applique les migrations au démarrage
+--------+---------+
         |
+--------v---------+
| db : PostgreSQL  |  16, volume de données persistant
+------------------+

backup : sauvegarde quotidienne de la base (pg_dump), rétention 14 jours
certbot : renouvellement du certificat TLS (seulement si Let's Encrypt)
```

Seul le service `web` publie des ports. L'API et la base ne sont joignables que depuis le réseau interne des conteneurs.

3. Système de gestion de base de données

Élément	Valeur
SGBD	PostgreSQL **16** (image officielle `postgres:16-alpine`)
Extensions	aucune
Schéma	`dqa`, créé et mis à jour par des migrations SQL versionnées, appliquées automatiquement au démarrage de l'API
Encodage, fuseau	UTF-8 ; fuseau `Africa/Abidjan`
Volume actuel	quelques dizaines de Mo (sauvegarde compressée : 4,6 Mo pour 3 mois et 40 sites)
Croissance estimée	moins de 1 Go par an au rythme d'un import hebdomadaire

La base peut aussi être hébergée sur une instance PostgreSQL 16 existante de la NPSP : il suffit de fournir une base dédiée et un compte propriétaire du schéma, et d'adapter la chaîne de connexion de l'API.

4. Système d'exploitation

Élément	Valeur
Système recommandé	Linux 64 bits : **Ubuntu Server 24.04 LTS** ou **Debian 12**
Moteur de conteneurs	Docker Engine 24 ou plus, avec le greffon Docker Compose v2
Architecture	x86_64 (amd64)

Les conteneurs embarquent leur propre environnement (Debian réduite pour l'API, Alpine pour Nginx et PostgreSQL). Aucun langage n'est à installer sur le serveur lui-même.

5. Langages, frameworks et dépendances

Couche	Technologie
API	Node.js **24** (LTS), TypeScript, NestJS 10, pilote PostgreSQL `pg`
Interface	Angular **21**, compilée en fichiers statiques servis par Nginx
Serveur web, proxy	Nginx **1.27**
Base de données	PostgreSQL **16**
Conteneurs	Docker, Docker Compose
Sécurité	mots de passe hachés (scrypt, bibliothèque standard Node) ; sessions par cookie `HttpOnly`, `Secure` en HTTPS

Le code source est sur un dépôt Git (GitHub). Les dépendances sont figées par un fichier de verrouillage (`package-lock.json`) : une installation est reproductible.

6. Ressources nécessaires

Ressource	Minimum	Recommandé
Processeur	2 vCPU	4 vCPU
Mémoire vive	4 Go	8 Go
Stockage	40 Go SSD	60 Go SSD

Détail du stockage : système et Docker environ 15 Go ; images des conteneurs environ 1,5 Go ; base de données inférieure à 1 Go la première année ; sauvegardes quotidiennes (14 jours) quelques centaines de Mo ; journaux. La marge couvre plusieurs années de données.

La charge est faible en consultation. Le pic de mémoire et de processeur a lieu pendant un import, lors du recalcul des indicateurs (une à deux minutes par semaine).

7. Ports, services et réseau

7.1 Flux entrants

Port	Service	Usage	Exposition
443/TCP	Nginx	application (HTTPS)	réseau des utilisateurs
80/TCP	Nginx	redirection vers HTTPS ; validation Let's Encrypt si ce mode est retenu	réseau des utilisateurs
22/TCP	SSH	administration du serveur	réseau d'administration de la DSI seulement

Ports internes, **jamais exposés** : 3000 (API) et 5432 (PostgreSQL).

7.2 Flux sortants

Destination	Usage	Quand
Docker Hub, registre npm, GitHub	construction des images, récupération du code	installation et mises à jour seulement
Let's Encrypt (`acme-v02.api.letsencrypt.org`)	certificat TLS	seulement si ce mode est retenu

En fonctionnement, l'application n'a besoin d'**aucun accès sortant**. Si le serveur ne doit pas accéder à Internet, les images peuvent être construites ailleurs et transférées (`docker save` puis `docker load`).

7.3 Nom de domaine et certificat

- Un nom DNS pointant vers le serveur (par exemple `sum.npsp.ci`), à fixer par la DSI.
- Certificat TLS, deux options :
- certificat fourni par la NPSP (PKI interne ou certificat commercial) : il est monté dans le conteneur Nginx, le service `certbot` est retiré ;

- certificat Let's Encrypt, si le serveur est joignable depuis Internet sur le port 80.

---

8. Sécurité

- Un seul point d'entrée (Nginx) ; API et base sans port publié.
- TLS 1.2 et 1.3 uniquement ; en-têtes de sécurité (HSTS, `nosniff`, `SAMEORIGIN`, `Referrer-Policy`).
- Conteneurs applicatifs exécutés sans droits `root`.
- Secrets (mot de passe de la base, domaine) dans un fichier d'environnement du serveur, hors du dépôt de code, lisible par l'administrateur seulement.
- Comptes applicatifs par rôle (lecteur, coordination, administrateur) ; les mots de passe initiaux sont changés à la mise en service.
- Données : mouvements, inventaires et réquisitions des produits suivis, par site. Les dispensations sont transmises sans l'identité du patient : la base ne contient aucune donnée patient nominative.

---

9. Sauvegarde et restauration

- Sauvegarde automatique quotidienne de la base (`pg_dump`, format compressé) dans un dossier du serveur, avec purge au-delà de 14 jours (réglable).
- Scripts fournis pour une sauvegarde immédiate et pour une restauration.
- **Demandé à la DSI :** copier ce dossier vers un stockage externe (règle 3-2-1), et sauvegarder séparément le fichier des secrets.

---

10. Déroulé de la migration

1. **DSI :** mise à disposition du serveur (section 6), du nom DNS, des flux (section 7) et d'un accès SSH pour l'installation.
2. Installation de Docker, récupération du code, renseignement du fichier d'environnement (domaine, mot de passe de la base, fuseau).
3. Mise en place du certificat TLS (option retenue en section 7.3).
4. Construction et démarrage des conteneurs : la base est créée et migrée automatiquement.
5. Reprise des données : restauration de la dernière sauvegarde de la base actuelle, ou rechargement des classeurs hebdomadaires de la DAP.
6. Vérifications : accès HTTPS, connexion, import d'un classeur de test, sauvegarde puis restauration sur une base jetable.
7. Changement des mots de passe des comptes initiaux et communication de l'adresse aux utilisateurs.

Durée estimée : une demi-journée une fois le serveur et les flux disponibles. La procédure complète est décrite dans le manuel de déploiement du projet (`docs/manuel_deploiement.md`).

11. Exploitation courante

- **Supervision :** une sonde HTTP sur `https://<domaine>/api/sante` (réponse 200 quand l'API et la base sont saines). Surveiller l'espace disque.
- **Mises à jour de l'application :** récupération du code puis redémarrage des conteneurs ; les migrations de la base s'appliquent seules.
- **Mises à jour de sécurité :** système hôte et images de base (PostgreSQL, Nginx, Node.js) selon la politique de la DSI.

12. Points à confirmer par la DSI

1. Accès à l'application : réseau interne NPSP seulement, ou aussi depuis Internet (les équipes district se connectent depuis leurs sites) ?
2. Nom de domaine retenu.
3. Certificat TLS : fourni par la NPSP, ou Let's Encrypt ?
4. PostgreSQL : dans un conteneur sur le serveur (recommandé), ou sur une instance mutualisée de la NPSP ?
5. Accès sortant du serveur pendant l'installation (Docker Hub, npm, GitHub), ou transfert d'images construites ailleurs ?
6. Politique de sauvegarde externe et de supervision en place.